Change Management Policy

COOKIE-BANNER.CA Effective Date: 2026-03-28 **Last Reviewed:** 2026-03-28 **Contact:** security@cookie-banner.ca
Classification: Internal

---

1. Purpose and Scope

This policy establishes a formal change management process for all modifications to the COOKIE-BANNER.CA cookie consent management platform (CMP), including application code, infrastructure configuration, database schemas, and third-party integrations.

It applies to all changes affecting the production environment: application deployments, database migrations, environment variable updates, DNS changes, Stripe configuration changes, and Supabase or Vercel settings modifications.

---

2. Change Classification

Classification	Description	Examples	Approval
Standard	Low-risk, routine changes following the established PR workflow	Bug fixes, copy updates, dependency patches, UI tweaks	Self-approved after PR checklist review
Significant	Changes affecting data models, authentication, billing, or privacy-related functionality	Prisma schema migrations, NextAuth config changes, Stripe webhook updates, consent logic changes	Requires documented risk assessment in the PR description before merge
Emergency	Urgent fixes for production outages, security vulnerabilities, or data integrity issues	Security patches, critical bug hotfixes, incident remediation	May bypass standard PR review; must be documented retroactively within 24 hours

---

3. Change Request and Approval Process

All changes follow a Git-based workflow using GitHub as the system of record:

1. **Branch**: Create a feature or fix branch from `develop`.
2. **Implement**: Develop the change with atomic, descriptive commits.
3. **Pull Request**: Open a PR against `develop` with:
   - Summary of what changed and why.
   - Change classification (standard, significant, or emergency).
   - Testing steps performed.
   - For significant changes: risk assessment and rollback plan.
4. **Review**: PR is reviewed against the checklist before merge. For significant changes, a cooling-off period of at least one hour is observed before merging.
5. **Merge**: Squash-merge into `develop`, triggering automated deployment.

The Founder serves as the sole Change Approver and is responsible for all merge decisions.

---

4. Testing Requirements

All changes must be verified before reaching production:

- **Vercel Preview Deployments**: Every PR generates a preview URL. The preview must be manually verified for UI/UX correctness and functional behavior.
- **Automated Tests**: Any existing test suites must pass before merge.
- **Database Migrations**: Must be tested against a non-production database (Supabase branch or local instance) before merging.
- **Significant Changes**: Require explicit testing of affected user flows (consent collection, banner rendering, dashboard functionality, Stripe billing) as documented in the PR.

---

5. Deployment Process

COOKIE-BANNER.CA uses Vercel for automated, immutable deployments:

- Merging a PR to `develop` triggers an automatic production deployment.
- Each deployment is an atomic, immutable snapshot with a unique URL.
- Vercel maintains a full deployment history, enabling instant rollback to any previous deployment.
- No manual server access or SSH is required; all deployments are managed through the Git-to-Vercel pipeline.

---

6. Rollback Procedures

Component	Rollback Method	Recovery Time
Application	Vercel Instant Rollback via the dashboard or CLI to any previous deployment	Minutes
Database	Supabase Point-in-Time Recovery (PITR) to restore to any point within the retention window	Minutes to hours depending on data volume
Environment Variables	Revert via Vercel dashboard; redeploy if needed	Minutes

For any rollback, a post-incident note must be added to the original PR or a follow-up issue documenting what was rolled back and why.

---

7. Database Changes

Database schema changes carry elevated risk and require additional diligence:

1. All schema changes are managed through **Prisma migrations** (`prisma migrate`).
2. Migration SQL must be reviewed in the PR diff before merge.
3. Migrations must be tested against a non-production database first.
4. Destructive operations (dropping columns/tables, changing types) require a two-phase approach: deprecate first, remove in a subsequent release.
5. Direct SQL modifications to the production database outside of Prisma migrations are prohibited except during emergency incident response.

---

8. Documentation Requirements

- **Commit Messages**: Must be descriptive and reference the intent of the change.
- **PR Descriptions**: Must include a summary, classification, and testing steps.
- **Significant Changes**: Must include a risk assessment and rollback plan in the PR.

- **Emergency Changes**: Must be retroactively documented within 24 hours with a post-incident summary.
- **Configuration Changes**: Changes to environment variables, Stripe settings, Supabase configuration, or DNS must be logged in the relevant PR or a dedicated change log issue.

---

9. Emergency Change Procedures

When a production incident requires immediate remediation:

1. **Assess**: Determine severity and whether an emergency change is warranted.
2. **Fix**: Implement the fix on a branch. If time permits, open a PR; if not, commit directly to `develop`.
3. **Deploy**: Merge or push to trigger deployment; alternatively, use Vercel Instant Rollback if reverting is sufficient.
4. **Document**: Within 24 hours, create or update a PR/issue with:
    - Description of the incident and its impact.
    - The change that was made.
    - Root cause (if known).
    - Steps to prevent recurrence.
5. **Review**: Retroactively review the emergency change to confirm it meets code quality standards.

---

10. Post-Deployment Verification

After every production deployment:

1. Verify the application loads correctly at the production URL.
2. Confirm the cookie consent banner renders and functions on a test site.
3. Check the Vercel deployment logs for errors.
4. For significant changes: verify the specific functionality affected (dashboard, billing, consent logging, API endpoints).
5. Monitor error tracking and application logs for 30 minutes following deployment.

---

11. Roles and Responsibilities

Role	Person	Responsibilities
Change Approver	Founder	Reviews and approves all changes; makes merge decisions; authorizes emergency changes
Change Implementer	Founder	Develops, tests, and deploys changes; writes documentation
Incident Responder	Founder	Responds to production incidents; executes emergency changes and rollbacks

As a solo-founder organization, all roles are held by the same individual. This policy ensures disciplined process adherence despite the absence of a second reviewer by requiring documented checklists, PR descriptions, and post-deployment verification.

---

12. Compliance Considerations

Changes affecting consent collection, data processing, or data storage must account for obligations under GDPR, PIPEDA, Quebec Law 25, and PECR. Any change to how personal data is collected, stored, or processed must include a privacy impact note in the PR description.

---

13. Review Schedule

This policy is reviewed **annually** or whenever a material change occurs to the platform architecture, team structure, or regulatory requirements. The next scheduled review is **2027-03-28**.

Approved by: Founder, COOKIE-BANNER.CA Date: 2026-03-28